



CODEPORTFOLIO · GOBIERNO Y CALIDAD

Matriz de Riesgos

Identificación, tratamiento, seguimiento y aceptación · CodePortfolio
1.0

Control	Valor
Código documental	CP-RSK-002
Versión	2.0
Fecha de corte	14 de septiembre de 2026
Autor / responsable	Pedro Bonilla
Estado	Línea base propuesta para revisión y aprobación
Proyecto	CodePortfolio — red social de portafolios de código

Control del documento

Historia de revisiones

Fecha	Versión	Descripción	Responsable
09/09/2026	1.0	Versiones iniciales y documento consolidado.	Pedro Bonilla
14/09/2026	2.0	Separación por entregable, contraste con el código, trazabilidad, criterios medibles y registros de evidencia.	Pedro Bonilla

Aprobación

Rol	Nombre	Decisión	Firma / fecha
Responsable del producto	Pedro Bonilla	☐ Aprobado ☐ Rechazado	_____
Aseguramiento de calidad	Pedro Bonilla	☐ Aprobado ☐ Rechazado	_____
Responsable de implantación	Pedro Bonilla	☐ Aprobado ☐ Rechazado	_____

1. Método y apetito de riesgo

Se valora probabilidad (P) e impacto (I) de 1 a 5. La exposición es P×I antes y después de controles. La matriz cubre riesgos de producto, proyecto, operación, seguridad, datos, cadena de suministro, calidad y adopción.

Valor	Probabilidad	Impacto
1	Rara: excepcional	Insignificante: sin interrupción ni dato afectado
2	Improbable	Menor: alternativa simple
3	Posible	Moderado: función/cronograma afectado
4	Probable	Mayor: flujo crítico, >1 día o datos en riesgo
5	Casi seguro	Catastrófico: pérdida/exposición, autorización eludida o indisponibilidad prolongada

P×I	Nivel	Tratamiento
1–4	Bajo (B)	Aceptar/observar
5–9	Medio (M)	Mitigar con responsable
10–14	Alto (A)	Plan y seguimiento frecuente
15–25	Crítico (C)	Bloquea liberación salvo reducción/aprobación excepcional

Apetito

No se acepta para producción riesgo residual crítico, ni riesgo alto de seguridad/integridad sin aprobación explícita y control compensatorio. Un riesgo materializado se gestiona además como hallazgo o defecto.

2. Registro de riesgos

ID	Riesgo	Categoría	P	I	Inh.	Dueño	Prevención / mitigación	Contingencia	Pr	Ir	Residual	Estado
R-01	Pérdida/corrupción de datos en migración o baja	Técnico	2	5	10 A	Implantación	Backup DB+imágenes; migración ensayada; cascadas probadas	Restore verificado; rollback; congelar escrituras	1	5	5 M	Abierto
R-02	Exposición de secretos o datos personales	Seguridad	3	5	15 C	Desarrollo	Variables; .gitignore; errores neutros; evidencia redactada	Rotar/revocar; aislar; investigar alcance; notificar según obligación	2	5	10 A	Abierto
R-03	Acceso indebido a recurso ajeno o rol Admin	Seguridad	3	5	15 C	Calidad	JWT; [Authorize]; propiedad; pruebas actor-recurso	Bloquear liberación; revocar sesiones; corregir y regresión	1	5	5 M	Abierto
R-04	Fuerza bruta / abuso del login	Seguridad	3	4	12 A	Desarrollo	10 solicitudes/min/cliente; mensajes neutros	Bloqueo temporal/WAF; revisar IP real y logs	2	4	8 M	Controlado
R-05	Archivo malicioso o agotamiento de almacenamiento	Seguridad	2	4	8 M	Desarrollo	Firma, tipo, 5 MB, nombre del servidor, volumen	Aislar/eliminar; ampliar cuota; escanear y revisar logs	1	4	4 B	Controlado
R-06	Indisponibilidad de contenedor/servidor	Operación	3	4	12 A	Operación	Restart; health DB; monitoreo; capacidad	Reiniciar/failover proveedor; restaurar versión estable	2	4	8 M	Abierto
R-07	Persona única concentra conocimiento y aprobación	Proyecto	4	4	16 C	Producto	Runbooks; repositorio; registros; capacitación cruzada	Revisor externo; suplente; congelar cambios de alto riesgo	3	4	12 A	Abierto
R-08	Requisito ambiguo o cambio tardío	Alcance	3	3	9 M	Producto	ERS versionada; criterios; control de cambios	Replanificar; diferir con aceptación; actualizar pruebas	2	3	6 M	Abierto
R-09	Estimación/calendario insuficiente	Proyecto	3	3	9 M	Producto	Hitos, puertas y seguimiento semanal	Reducir alcance no crítico; priorizar defectos y controles	2	3	6 M	Abierto
R-10	Degradación de rendimiento/crecimiento	Técnico	3	3	9 M	Desarrollo	Paginación; índices; límite 50; meta p95	Optimizar consulta/índice; limitar tráfico; escalar recursos	2	3	6 M	Abierto
R-11	Vulnerabilidad de dependencia o imagen	Cadena suministro	3	4	12 A	Desarrollo	Lockfile; imágenes versionadas; revisión/escaneo	Actualizar/pinear; retirar versión; aceptar temporalmente con control	2	4	8 M	Abierto
R-12	Contenido abusivo / enlaces externos dañinos	Producto	3	3	9 M	Producto	Moderación Admin; rel=noopener; reporte por soporte	Retirar contenido/usuario; registrar evidencia; bloquear dominio	2	3	6 M	Abierto
R-13	Pérdida o inconsistencia de imágenes	Datos	3	3	9 M	Operación	Volumen persistente; backup conjunto; sustitución controlada	Restaurar volumen; marcador temporal; reconciliar referencias	2	3	6 M	Abierto
R-14	Despliegue fallido / etiqueta incorrecta	Operación	3	4	12 A	Implantación	Gates; tag/hash; ensayo; humo; versión anterior	Rollback ≤30 min; comunicar; análisis causal	1	4	4 B	Abierto
R-15	Baja adopción o errores de usuario	Adopción	2	3	6 M	Capacitación	Práctica; evaluación; guía; soporte 2 semanas	Refuerzo; tutoría; mejorar interfaz/material	1	3	3 B	Abierto

ID	Riesgo	Categoría	P	I	Inh.	Dueño	Prevención / mitigación	Contingencia	Pr	Ir	Residual	Estado
R-16	Inconsistencia de idioma y mensajes	Calidad	4	2	8 M	Desarrollo	RNF-10; catálogo; revisión	Corregir strings; regresión; aceptar explícitamente si se difiere	2	2	4 B	Materializado
R-17	Ausencia de evidencia backend/E2E/restore	Calidad	4	5	20 C	Calidad	Plan, puertas G2/G3, formatos de evidencia	No liberar; habilitar herramientas; ejecutar y documentar	1	5	5 M	Materializado
R-18	Candidato no reproducible por cambios locales/sin tag	Configuración	4	4	16 C	Desarrollo	Árbol limpio; tag; digest; migraciones inventariadas	Congelar, revisar e identificar nueva línea base	1	4	4 B	Materializado
R-19	TLS/CORS/proxy mal configurados	Operación/seguridad	3	5	15 C	Operación	Overlay producción; allowlist; prueba externa; headers	Retirar exposición; corregir; rotar secretos si hubo fuga	1	5	5 M	Abierto
R-20	Borrado en cascada incompleto o excesivo	Datos	2	5	10 A	Desarrollo	FK revisadas; pruebas de huérfanos; backup	Restaurar; corregir migración/repositorio; regresión	1	5	5 M	Abierto

3. Indicadores, disparadores y escalamiento

Riesgo(s)	Indicador / disparador	Umbral	Acción
R-01/R-13/R-20	Backup/restore, conteos, huérfanos	Un restore fallido o diferencia no explicada	No-go; investigar y repetir
R-02/R-03/R-04/R-05/R-19	Alertas, 401/403/429, secretos, archivos	Una fuga o bypass; aumento anómalo	Contener y escalar de inmediato
R-06/R-10	5xx, p95, reinicios, CPU/RAM/disco	5xx ≥ 1 % o p95 >500 ms sostenido	Diagnóstico; capacidad; rollback si afecta críticos
R-07	Revisiones y cobertura de suplente	Sin revisor/suplente en G3	Reprogramar o aceptar formalmente exposición
R-11	Escaneo de paquetes/imágenes	CVE crítica/alta explotable	Bloquear hasta parche/control aprobado
R-16	Mensajes no españoles	Cualquier mensaje de usuario	Corregir o registrar excepción RNF-10
R-17	Casos con resultado y evidencia	<100 % críticos o backend sin resultado	No liberar
R-18	Git status/tag/digest	Árbol sucio o versión sin identificar	Congelar nueva línea base

4. Priorización actual

Prioridad	Riesgos	Decisión requerida
1 · Bloqueantes actuales	R-17, R-18	Habilitar/ejecutar backend y E2E; integrar cambios y etiquetar candidato.
2 · Críticos inherentes	R-02, R-03, R-07, R-19	Probar controles; incorporar revisor/suplente; verificar producción.
3 · Altos operativos	R-01, R-04, R-06, R-11, R-14, R-20	Ensayo, restore, escaneo, monitoreo y rollback.
4 · Calidad materializada	R-16	Resolver mensajes en inglés o ajustar el requisito.

5. Cadencia y ciclo de vida

1. Revisar semanalmente y en cada puerta G0–G5; registrar fecha, cambio de P/I, evidencia y decisión.
2. El dueño ejecuta acciones; calidad desafía valoración y verifica evidencia; producto acepta el residual.
3. Cerrar solo si la causa desaparece o el control demuestra riesgo bajo estable. Conservar el registro histórico.

4. Todo incidente actualiza esta matriz, el plan de pruebas y, si aplica, requisitos, capacitación o implantación.

5.1 Registro de revisión

Fecha	Riesgo	Cambio / evidencia	P/I residual	Decisión	Responsable

6. Aceptación de riesgos

ID	Residual aceptado	Justificación / control compensatorio	Vencimiento	Aprobador / firma
	☐ Sí ☐ No			
	☐ Sí ☐ No			
	☐ Sí ☐ No			
	☐ Sí ☐ No			
	☐ Sí ☐ No			

Mejora frente a la matriz previa

La versión inicial listaba riesgo, P, I y mitigación, pero no tenía dueño, riesgo residual, estado, disparadores, apetito, aceptación ni registro de revisión. Esta matriz incorpora esos controles y añade los riesgos materializados durante la revisión del repositorio.